

Project Compass Guidelines

Purpose. Compass is a web app that helps organizations find AI tools in use, understand AI governance gaps, and turn findings into clear dashboards and reports. The project uses the NIST AI Risk Management Framework as the structure, but presents the work in simple language for security, leadership, and audit users.

Main users. The main users are security leads, compliance officers, auditors, and business leaders. The security lead is the primary MVP user because they need to find AI activity, review risk, and decide what should be fixed first.

Problem. Many companies use AI tools before they have strong policies, monitoring, ownership, or review steps. This can create risk around private company data, customer data, legal exposure, and unclear accountability.

Updated MVP Flow

Step	What Compass Does	Frontend Focus
1. Upload Logs	Accept DNS, firewall, web proxy, and cloud log samples.	Clear upload screen with file preview and status.
2. Detect AI Tools	Match log activity to known AI tool domains and services.	Show detected tools, source logs, users, and confidence.
3. AI Inventory	Create a working inventory from technical evidence instead of memory alone.	Inventory table with filters, evidence, and review states.
4. Gap Assessment	Ask follow-up governance questions only after tools are detected.	Guided questions mapped to Govern, Map, Measure, and Manage.
5. Dashboard + Actions	Rank gaps and recommend next steps.	Risk cards, priority list, and top actions.
6. Export Reports	Create executive, security, and auditor outputs.	PDF export and three audience views.

Product Guidelines

Evidence first: Compass should begin with logs and system evidence, not only employee memory.

Plain language: Use short labels and clear definitions. Avoid heavy framework language in the main workflow.

Traceable findings: Each finding should show the evidence source, risk reason, NIST area, and action item.

Audience aware: Executive, security, and auditor views should reuse the same findings but adjust the detail level.

Action oriented: Every high risk finding should lead to a practical next step.

Design, Security, Reporting, and Success Rules

Design Guidelines

Area	Guideline
Look and feel	Clean, professional, trustworthy, and easy to scan. Use navy, blue, white, light gray, and teal accents.
Navigation	Keep the user moving through the flow: upload, detect, inventory, assess, dashboard, action, report.
Language	Write in simple words. Explain risk in business terms first, then provide technical detail where needed.
Dashboard	Show the highest risks first. Use cards, tables, filters, and clear status labels.

Security and Data Handling Guidelines

Compass may handle sensitive technical evidence, so the product should show careful security thinking. The demo should use sample or scrubbed logs. Any stored data should be limited to what the demo needs, and the interface should explain what was uploaded, what was detected, and what will be retained.

Report Guidelines

Report View	Should Emphasize
Executive	Business impact, legal exposure, financial risk, and top decisions. No heavy technical language.
Security	Missing controls, risk severity, source evidence, NIST mapping, and action priority.
Auditor	Assessment evidence, framework mapping, dates, scope, and structured findings.

After Scan Actions

For the MVP, Compass should focus on the highest two after-scan actions: block risky tools and add monitoring. Future actions can include approving safer tools, creating Active Directory or cloud access policies, reviewing vendors, and assigning tool owners.

Success Criteria

- A user can understand the flow in under five minutes.
- The AI inventory is created from log evidence, not memory alone.
- The dashboard clearly shows the highest risk gaps and the top actions.
- The final PDF can be shared with leadership, security teams, or auditors.
- The product feels realistic enough to support a capstone demo and future plugin direction.